01 RAG for Secure Code

AI-Assisted Static Analysis in CI

Danil Kovalev · Group VKB53 / Ковалев Данил · группа ВКБ53

B2 • 12 slides • 1277 English words • about 10–12 minutes with pauses and slide builds

English — speaking text

Today I would like to explain how retrieval-augmented generation, or RAG, can support security analysis of source code. My practical example is a software module that I developed for continuous integration, usually called CI. The module combined a language model with external security knowledge.

It also used GraphRAG and Agentic RAG. I will explain the problem, describe the main components, and discuss research evidence and costs. My main question is this: how can we give an AI scanner useful evidence while keeping its findings practical to review?

Русский перевод

Сегодня я хотел бы объяснить, как генерация с дополнением поиском, или RAG, может помогать анализировать безопасность исходного кода. Мой практический пример — программный модуль, который я разработал для непрерывной интеграции, обычно называемой CI. Модуль сочетал языковую модель с внешними знаниями по безопасности.

В нём также использовались GraphRAG и Agentic RAG. Я объясню проблему, опишу основные компоненты и рассмотрю результаты исследований и затраты. Главный вопрос такой: как предоставить ИИ-сканеру полезные сведения и при этом сделать его находки удобными для проверки?

Показ слайда: Начни спокойно. Раскрой CI: Continuous Integration. Схема появляется одним кликом.

02 Contents

English — speaking text

The presentation has five parts. First, I will explain why a language model needs additional security knowledge. Second, I will show how a basic RAG pipeline works and how it fits into my CI module. Third, we will look at published research on vulnerability detection.

After that, I will explain graph-based retrieval and agent-driven analysis, including the roles of AG2 and FastMCP. Finally, I will discuss costs, evaluation, and the main conclusions. Throughout the presentation, I will distinguish my project experience from results reported by other researchers.

Русский перевод

В презентации пять частей. Сначала я объясню, зачем языковой модели нужны дополнительные знания по безопасности. Затем покажу, как работает базовый RAG-пайплайн и какое место он занимает в моём CI-модуле. В третьей части мы рассмотрим опубликованное исследование обнаружения уязвимостей.

После этого я объясню поиск по графу и анализ под управлением агентов, включая роли AG2 и FastMCP. В конце я рассмотрю затраты, оценку качества и основные выводы. На протяжении доклада я буду отделять свой проектный опыт от результатов, опубликованных другими исследователями.

Показ слайда: Покажи маршрут целиком. На этом слайде не нужно подробно объяснять каждый пункт.

03 Why AI Code Review Needs Security Knowledge

English — speaking text

A code fragment rarely contains everything needed to judge its security. A model may miss the meaning of an input, a dangerous operation, or a protection implemented elsewhere. Security guidance can provide additional context and explain why a pattern is risky. OWASP publishes security guidance and risk categories. CWE describes types of weaknesses, while CVE records identify specific publicly disclosed vulnerabilities.

The screenshot shows CWE-89, which describes SQL injection. These resources have different roles. A knowledge base can combine relevant material, but its quality and freshness matter. The goal is to use external knowledge to improve code review and make the reasoning easier for a developer to check.

Русский перевод

Фрагмент кода редко содержит всё необходимое для оценки его безопасности. Модель может не понять назначение входных данных, опасную операцию или защиту, реализованную в другом месте. Рекомендации по безопасности дают дополнительный контекст и объясняют, почему определённый шаблон опасен. OWASP публикует рекомендации и категории рисков. CWE описывает типы слабостей, а записи CVE обозначают конкретные публично раскрытые уязвимости.

На скриншоте показана CWE-89 — SQL-инъекция. Эти источники выполняют разные роли. База знаний может объединять подходящие материалы, однако важны их качество и актуальность. Цель — использовать внешние знания для улучшения проверки кода и сделать рассуждение более понятным разработчику.

Показ слайда: Обрати внимание на настоящий скриншот CWE-89. Объясни разницу OWASP, CWE и CVE простыми словами.

04 How a Basic RAG Pipeline Works

English — speaking text

A basic RAG system has a preparation stage and an analysis stage. During preparation, security documents are split into smaller passages. Their representations are stored in a searchable index. During analysis, the system creates a search query from the code and the review task. The retriever finds relevant passages. Relevant passages are added to the prompt, together with the code.

The language model then produces an assessment using this context. The small code block is illustrative pseudocode. It shows the order of operations rather than a complete application. An important advantage is that documents can be updated separately from the model. However, a weak search result can still lead to a weak assessment.

Русский перевод

В базовой RAG-системе есть этап подготовки и этап анализа. При подготовке документы по безопасности делятся на небольшие фрагменты. Их представления сохраняются в индексе для поиска. Во время анализа система формирует поисковый запрос на основе кода и задачи проверки. Поисковый компонент находит релевантные фрагменты. Эти фрагменты добавляются в запрос к модели вместе с кодом.

Затем языковая модель формирует оценку с учётом полученного контекста. Небольшой блок кода — это учебный псевдокод. Он показывает порядок операций, а не полное приложение. Важное преимущество заключается в том, что документы можно обновлять отдельно от модели. Однако неудачный результат поиска всё ещё может привести к некачественной оценке.

Показ слайда: Клик 1: подготовка базы. Клик 2: поиск. Клик 3: анализ с контекстом. Клик 4: покажи учебный псевдокод.

05 My CI Security Module

English — speaking text

In my project, I wrote a software module that scans a codebase for potential vulnerabilities inside a CI workflow. I configured a RAG pipeline using OWASP material and other security sources. Knowledge collected from OWASP supported code analysis. The implementation also included GraphRAG and Agentic RAG, with AG2 and FastMCP as parts of the technology stack. This diagram presents the main responsibilities at a high level.

Code enters the analysis process, relevant knowledge is retrieved, and the model assesses possible weaknesses. The output is a set of findings that can be reviewed. The practical value is bringing security knowledge into the development workflow. The diagram simplifies the implementation; it does not present a measured benchmark of my module.

Русский перевод

В своём проекте я написал программный модуль, который сканирует кодовую базу на потенциальные уязвимости в рамках CI-процесса. Я настроил RAG-пайплайн на основе материалов OWASP и других источников по безопасности. Знания, собранные из OWASP, использовались при анализе кода. Реализация также включала GraphRAG и Agentic RAG, а AG2 и FastMCP были частью технологического стека. Эта схема показывает основные зоны ответственности на общем уровне.

Код поступает на анализ, система находит релевантные знания, и модель оценивает возможные слабости. На выходе получается набор находок, которые можно проверить. Практическая польза — включение знаний по безопасности в процесс разработки. Схема упрощает реализацию и не является измеренным результатом тестирования моего модуля.

Показ слайда: Клик 1: код в CI. Клик 2: поиск знаний и GraphRAG. Клик 3: агенты и инструменты. Клик 4: результаты анализа. Не называй схему точным исходным кодом проекта.

06 Research Evidence: Vul-RAG

English — speaking text

A closely related study is Vul-RAG. Its authors retrieved knowledge about vulnerability causes and fixes to guide code assessment. The chart compares the same reported model, GPT-4o, with a basic prompt and with Vul-RAG. On the PairVul benchmark, pair accuracy increased from eight percent to thirty-two percent. That is an increase of twenty-four percentage points.

Pair accuracy is a strict measure: both the vulnerable function and its patched version must be classified correctly. The dataset contained five hundred and eighty-six pairs. These results support the value of carefully selected security knowledge in this experiment. They also show that the task remains difficult. These are published research results, not measurements of my CI module.

Русский перевод

Близкое по теме исследование — Vul-RAG. Его авторы находили знания о причинах уязвимостей и способах исправления, чтобы направлять оценку кода. На графике сравнивается одна и та же указанная в статье модель GPT-4o: с базовым запросом и с Vul-RAG. На наборе PairVul точность по парам выросла с восьми до тридцати двух процентов. Это рост на двадцать четыре процентных пункта.

Точность по парам — строгая метрика: система должна правильно классифицировать и уязвимую функцию, и её исправленную версию. В наборе было пятьсот восемьдесят шесть пар. Результаты подтверждают пользу тщательно выбранных знаний по безопасности в данном эксперименте. Они также показывают, что задача остаётся сложной. Это опубликованные результаты исследования, а не измерения моего CI-модуля.

Показ слайда: Клик: раскрой график. Подчеркни: это результаты статьи, а метрика оценивает обе функции в паре.

07 GraphRAG: Connecting Related Facts

English — speaking text

Some security questions require connecting several pieces of information. A graph represents entities as nodes and relationships as links. In a security-analysis setting, an illustrative graph might connect a code element, a weakness type, and remediation guidance. Graph-based retrieval can use these relationships to gather broader context. My module included GraphRAG.

The small graph on this slide explains the idea; it is not a copy of my project's data structure. The screenshot comes from Microsoft's GraphRAG documentation. That implementation also uses community summaries for questions about larger collections. Building and updating a graph introduces extra work. Graph relationships can help retrieval, but they do not prove that a reported vulnerability is real.

Русский перевод

Для некоторых вопросов безопасности нужно связать несколько фрагментов информации. Граф представляет сущности в виде узлов, а отношения — в виде связей. В контексте анализа безопасности учебный граф может связывать элемент кода, тип слабости и рекомендации по исправлению. Поиск по графу может использовать эти отношения для получения более широкого контекста. Мой модуль включал GraphRAG.

Небольшой граф на слайде объясняет идею и не является копией структуры данных моего проекта. Скриншот взят из документации Microsoft GraphRAG. В этой реализации также используются сводки сообществ для вопросов о больших коллекциях. Построение и обновление графа требуют дополнительных усилий. Связи могут помогать поиску, однако они не доказывают, что найденная уязвимость реальна.

Показ слайда: Клик 1: узлы. Клик 2: связи. Скриншот справа — официальный пример Microsoft, не граф личного проекта.

08 Agentic Analysis with AG2 and FastMCP

English — speaking text

Agentic RAG allows the system to decide when it needs more information. For example, an agent can retrieve guidance, assess whether the evidence is sufficient, and request additional context before producing a finding. AG2 provides a framework for organizing agents and tool use. FastMCP exposes Python functions as tools through the Model Context Protocol. These libraries have different responsibilities.

The code shows a minimal FastMCP tool that returns a piece of curated security guidance. It does not implement the whole retrieval system. Agentic analysis is useful when one fixed search is insufficient, but repeated steps increase latency and cost. A practical workflow therefore needs a step limit and a clear stopping condition.

Русский перевод

Agentic RAG позволяет системе определять, когда ей нужна дополнительная информация. Например, агент может найти рекомендации, оценить достаточность сведений и запросить дополнительный контекст перед формированием находки. AG2 предоставляет средства для организации агентов и использования инструментов. FastMCP открывает Python-функции как инструменты через протокол MCP — Model Context Protocol. Эти библиотеки выполняют разные задачи.

В коде показан минимальный инструмент FastMCP, который возвращает заранее подготовленную рекомендацию по безопасности. Он не реализует всю систему поиска. Агентный анализ полезен, когда одного фиксированного поиска недостаточно, однако повторные шаги увеличивают задержку и стоимость. Поэтому практическому процессу нужны ограничение числа шагов и понятное условие остановки.

Показ слайда: Клик 1: агент и AG2. Клик 2: инструменты FastMCP. Клик 3: возврат за дополнительным контекстом. Клик 4: пример кода. Объясни, что это минимальный инструмент.

09 Which Approach Fits the Task?

English — speaking text

The table compares three approaches. Basic RAG works well when a question can be answered from a small set of relevant passages. GraphRAG adds relationships and can help when the answer depends on connected information. Agentic RAG adds decisions about the next action, so the system can change its search strategy. Each approach introduces different costs.

A basic pipeline needs an index and retrieval. A graph needs construction and updates. An agent may make additional model and tool calls. These approaches can be combined, as in the overall design of my module. The important decision is which additional capability a particular analysis task actually needs.

Русский перевод

В таблице сравниваются три подхода. Базовый RAG подходит для вопросов, на которые можно ответить по небольшому набору релевантных фрагментов. GraphRAG добавляет отношения и может помогать, когда ответ зависит от связанных сведений. Agentic RAG добавляет выбор следующего действия, позволяя системе менять стратегию поиска. У каждого подхода свои источники затрат.

Базовому пайплайну нужны индекс и поиск. Граф нужно строить и обновлять. Агент может делать дополнительные вызовы модели и инструментов. Эти подходы можно сочетать, как в общей организации моего модуля. Главный вопрос — какая дополнительная возможность действительно нужна конкретной задаче анализа.

Показ слайда: Сравни строки таблицы. Подчеркни, что подходы можно сочетать — это не взаимоисключающие продукты.

10 When Does RAG Save Money?

English — speaking text

RAG can reduce inference costs by sending selected evidence instead of a large collection of documents. However, indexing, storage, retrieval, evaluation, and maintenance also cost money. Caching can make the alternative cheaper, so a fair comparison must include it. The chart shows a published GraphRAG optimization, rather than my project costs. Microsoft compared static and dynamic global search on fifty AP News questions.

Dynamic selection reduced average token cost by seventy-seven percent at the same community level. No statistically significant difference was found in the three evaluated quality measures. This result applies to that experiment. For a CI scanner, useful savings depend on the number of scans, model calls, and the developer time spent reviewing findings.

Русский перевод

RAG может снижать расходы на генерацию, передавая выбранные сведения вместо большой коллекции документов. Однако индексирование, хранение, поиск, оценка и сопровождение тоже стоят денег. Кеширование может удешевить альтернативный подход, поэтому его нужно учитывать при честном сравнении. График показывает опубликованную оптимизацию GraphRAG, а не расходы моего проекта. Microsoft сравнила статический и динамический глобальный поиск на пятидесяти вопросах по материалам AP News.

При одинаковом уровне сообществ динамический отбор снизил среднюю стоимость токенов на семьдесят семь процентов. Статистически значимого различия по трём оцениваемым показателям качества не обнаружили. Результат относится к данному эксперименту. Для CI-сканера полезная экономия зависит от числа проверок, вызовов модели и времени разработчика на разбор находок.

Показ слайда: Клик: график затрат. 77% относится к стоимости токенов конкретного эксперимента Microsoft, а не к твоему CI-модулю.

11 Evaluating an AI-Assisted Scanner

English — speaking text

Retrieving evidence is only the first step. We expect the scanner to support each finding with evidence. Evaluation should measure precision, which tells us what proportion of reported findings are correct, and recall, which tells us what proportion of known problems are found. We should also check whether cited documents actually support the explanation.

Other important measures are runtime, cost per scan, and the effort needed for human review. Code and retrieved documents should be treated as data, because they may contain instructions that try to mislead the model. A convincing evaluation needs a labeled test set and careful separation between development examples and test cases. Fluent explanations alone are insufficient evidence of security quality.

Русский перевод

Поиск сведений — только первый шаг. Мы ожидаем, что сканер будет подкреплять каждую находку доказательствами. При оценке нужно измерять точность: какая доля сообщённых находок действительно верна, и полноту: какая доля известных проблем обнаружена. Также следует проверять, действительно ли указанные документы подтверждают объяснение.

Другие важные показатели — время работы, стоимость одной проверки и трудозатраты на ручной разбор. Код и найденные документы следует рассматривать как данные, поскольку они могут содержать инструкции, пытающиеся ввести модель в заблуждение. Для убедительной оценки нужны размеченный тестовый набор и чёткое разделение примеров для разработки и тестовых случаев. Само по себе связное объяснение ещё не доказывает качество анализа безопасности.

Показ слайда: Произнеси предложение с Complex Object. Находка модели требует проверки. Клик раскрывает итоговую фразу.

12 Conclusions

English — speaking text

To conclude, RAG connects a language model to external security knowledge. In my CI module, I used this idea together with GraphRAG, Agentic RAG, AG2, and FastMCP to support static code analysis. Graphs help organize related information, while agents can decide when more context is needed. Published research provides encouraging examples, but its results must be interpreted within the tested settings.

The practical goal is to produce useful, evidence-supported findings at an acceptable cost. Better security analysis requires good retrieval, clear tool responsibilities, and careful validation. Thank you for your attention.

Русский перевод

В заключение: RAG связывает языковую модель с внешними знаниями по безопасности. В своём CI-модуле я использовал эту идею вместе с GraphRAG, Agentic RAG, AG2 и FastMCP для поддержки статического анализа кода. Графы помогают организовывать связанные сведения, а агенты могут определять, когда нужен дополнительный контекст. Опубликованные исследования дают обнадёживающие примеры, но их результаты нужно понимать в рамках проверенных условий.

Практическая цель — получать полезные находки, подкреплённые сведениями из источников, при приемлемых затратах. Для качественного анализа безопасности нужны хороший поиск, понятные роли инструментов и тщательная проверка. Спасибо за внимание.

Показ слайда: Подведи итог по трём тезисам. Выдержи паузу перед последним предложением.

Grammar checklist / Обязательная грамматика

Все примеры ниже присутствуют в видимом английском тексте презентации. Слайды указаны по номеру.

Active Voice — Slide 4

The retriever finds relevant passages.

Действительный залог: подлежащее the retriever выполняет действие finds.

Passive Voice — Slide 4

Relevant passages are added to the prompt.

Страдательный залог: are + added (Past Participle); действие направлено на фрагменты.

Infinitive — Slide 3

Use external knowledge to improve code review.

Инфинитив цели: to improve — чтобы улучшить проверку кода.

Gerund — Slide 11

Retrieving evidence is only the first step.

Герундий Retrieving с дополнением evidence образует подлежащее: поиск подтверждающих сведений.

Participle — Slide 5

Knowledge collected from OWASP supports code analysis.

Причастие II collected входит в определение collected from OWASP: знания, собранные из OWASP.

Compound Noun — Slide 4

knowledge base

Составное существительное: knowledge + base — база знаний. Другие примеры: source code, language model.

Complex Object — Slide 11

We expect the scanner to support each finding with evidence.

Сложное дополнение после expect: the scanner + to support (существительное и инфинитив). Мы ожидаем, что сканер будет подкреплять каждую находку доказательствами.

Glossary / Термины

RAG — Retrieval-Augmented Generation
генерация с дополнением поиском

CI — Continuous Integration
непрерывная интеграция

Static analysis — Analyzing code without running it
статический анализ: изучение кода без его выполнения

Knowledge base — A collection of information used by a system
база знаний

Retrieval — Finding relevant information
поиск релевантной информации

Embedding — A numerical representation of information
числовое представление информации

GraphRAG — Retrieval using graph-based knowledge
поиск с использованием графового представления знаний

Agentic RAG — An agent chooses retrieval actions
агент выбирает действия поиска

MCP — Model Context Protocol
протокол подключения инструментов и ресурсов к ИИ-приложениям

Weakness — A flaw that may lead to a vulnerability
слабость, способная привести к уязвимости

Finding — A reported potential problem
сообщение о потенциальной проблеме

False positive — An incorrect report of a problem
ложное срабатывание

Precision / recall — Correct findings / coverage of known problems
точность / полнота обнаружения

Pair accuracy — Both functions in a pair are classified correctly
доля пар с правильной оценкой обеих функций

Reranking — Sorting retrieved results again by relevance
повторное ранжирование найденных результатов

References / Источники

Личный проект описан на основе сведений автора. Показатели Vul-RAG и Microsoft относятся к внешним исследованиям. Учебные схемы и примеры кода не являются исходниками личного проекта.

1. Lewis et al. — Retrieval-Augmented Generation (2020)
https://arxiv.org/abs/2005.11401

2. OWASP — Top 10 project
https://owasp.org/www-project-top-ten/

3. MITRE — About CWE
https://cwe.mitre.org/about/index.html

4. MITRE — CWE-89: SQL Injection
https://cwe.mitre.org/data/definitions/89.html

5. Anthropic — Introducing Contextual Retrieval (2024)
https://www.anthropic.com/research/contextual-retrieval

6. Du et al. — Vul-RAG, arXiv v3 (2025), Tables 1 and 4
https://arxiv.org/html/2406.11147v3

7. Microsoft — GraphRAG documentation
https://microsoft.github.io/graphrag/

8. Edge et al. — From Local to Global: A GraphRAG Approach
https://arxiv.org/abs/2404.16130

9. LangGraph — Build a custom RAG agent
https://docs.langchain.com/oss/python/langgraph/agentic-rag

10. AG2 — Official repository and documentation
https://github.com/ag2ai/ag2

11. FastMCP — Official quickstart
https://gofastmcp.com/docs/getting-started/quickstart

12. Microsoft Research — Dynamic community selection (2024)
https://www.microsoft.com/en-us/research/blog/graphrag-improving-global-search-via-dynamic-community-selection/

13. OWASP — LLM01:2025 Prompt Injection
https://genai.owasp.org/llmrisk/llm01-prompt-injection/

How to present / Подготовка к выступлению

Открой PPTX в настольном Microsoft PowerPoint и запусти показ слайдов. Схемы раскрываются по клику; PDF показывает их итоговое статическое состояние.

Прочитай английский текст с секундомером. Ориентир — 115–130 слов в минуту с короткими паузами на схемы и графики. Точное число слов указано в начале документа.

На слайде 6 объясни, что pair accuracy оценивает сразу две функции. Рост 8% → 32% равен 24 процентным пунктам. Это не точность личного сканера.

На слайде 10 говори о стоимости токенов конкретного эксперимента Microsoft. Снижение на 77% не означает такую же экономию всего проекта.

Произношение: RAG — «рэг»; CI — «си-ай»; AG2 — «эй-джи-ту»; MCP — «эм-си-пи»; CWE — «си-дабл-ю-и». Для GraphRAG удобно говорить «граф-рэг».

Если спросят о результатах твоего проекта, опирайся на собственные реальные измерения и примеры. Графики презентации относятся к явно указанным публикациям.